SCIENCE
SCIENTIFIC JOURNAL

Sistema de Avaliação de Maturidade em Segurança Digital para Instituições Educacionais com Base no NIST CSF e LGPD

Digital Security Maturity Assessment System for Educational Institutions Based on NIST CSF and LGPD

Fernanda Holanda Sandir Campos (Orientador)

Resumo: Instituições educacionais, ao lidarem com dados sensíveis, evidenciam uma baixa maturidade em segurança digital e governança, o que resulta em vulnerabilidade e não conformidade com a Lei Geral de Proteção de Dados (LGPD). Propõe-se o desenvolvimento de um modelo simplificado de avaliação da maturidade em segurança digital, que se fundamente no NIST Cybersecurity Framework (CSF) e na LGPD, em conjunto com um sistema que inclua um dashboard de indicadores de risco para subsidiar a tomada de decisões.

A metodologia empregada compreende pesquisa bibliográfica, definição de controles específicos para o setor educacional, aplicação de questionário e a implementação de um sistema para o cálculo de indicadores ponderados e a subsequente visualização do nível de maturidade. O presente modelo é submetido a uma validação por meio de uma aplicação piloto.

Objetiva-se que se identifiquem vulnerabilidades, se mensurar os riscos inerentes e se forneçam recomendações práticas, o que contribui para o aprimoramento da governança de segurança digital neste setor.

Palavras-chave: Segurança Digital, NIST Cybersecurity Framework, LGPD, Maturidade em Segurança da Informação, Governança Digital, Indicadores de Risco, Educação, Soberania Digital

Abstract: Educational institutions, when dealing with sensitive data, show low maturity in digital security and governance, which results in vulnerability and non-compliance with the General Data Protection Law (LGPD). The development of a simplified model for assessing digital security maturity is proposed, based on the NIST Cybersecurity Framework (CSF) and the LGPD, along with a system that includes a risk indicator dashboard to support decision-making.

The methodology employed includes bibliographic research, definition of specific controls for the educational sector, application of a questionnaire, and the implementation of a system for calculating weighted indicators and the subsequent visualization of the maturity level. This model is subjected to validation through a pilot application.

The objective is to identify vulnerabilities, measure inherent risks, and provide practical recommendations, which contributes to the improvement of digital security governance in this sector.

Keywords: Digital Security, NIST Cybersecurity Framework, LGPD, Information Security Maturity, Digital Governance, Risk Indicators, Education, Digital Sovereignty

Introdução

Atualmente, a internet é indispensável em diversas atividades pedagógicas, o que resulta em um aumento significativo da exposição de estudantes ao ciberespaço e aos seus riscos inerentes. Nesse cenário, as instituições educacionais tornaram-se responsáveis pelo tratamento de um grande volume de dados pessoais sensíveis, que abrangem

desde registros acadêmicos até informações socioeconômicas, entre outros dados críticos. No entanto, muitas dessas organizações ainda operam com uma estrutura limitada de governança em segurança da informação, tornando-as alvos vulneráveis a ameaças cibernéticas contemporâneas.

A conformidade com a Lei Geral de Proteção de Dados (LGPD) impõe a essas instituições a obrigação legal de adotar medidas de segurança e transparência no tratamento de dados. Paralelamente, o NIST Cybersecurity Framework (CSF) 2.0 oferece uma taxonomia de resultados de alto nível que permite a organizações, independentemente de seu porte ou nível de maturidade, gerenciar e comunicar riscos de cibersegurança. Estudos internacionais, como os conduzidos pela Agência da União Europeia para a Cibersegurança (ENISA), reforçam a necessidade de modelos de avaliação de maturidade específicos para o contexto educacional, capazes de identificar lacunas de proteção.

Diferencial: Soberania Digital em Educação

Enquanto a conformidade com LGPD é obrigatória, a soberania digital em educação é uma questão estratégica pouco explorada. Instituições educacionais brasileiras dependem crescentemente de plataformas estrangeiras (Google Classroom, Microsoft 365, AWS, etc.) para operações críticas. Este modelo diferencia-se ao permitir:

- Identificar gaps de soberania: Dados ficam no Brasil ou exterior? Infraestrutura é própria ou terceirizada?
- Avaliar risco geopolítico: Embargo, mudança de políticas, dependência tecnológica
- Planejar autonomia operacional: Migração para infraestrutura aberta, dados soberano-compatíveis

Diante da lacuna entre exigências legais e capacidade técnica institucional, aliada à necessidade de autonomia operacional, este trabalho propõe um modelo simplificado de avaliação de maturidade em segurança digital. O modelo integra os requisitos da LGPD às cinco funções centrais do NIST CSF: Identify (Identificar), Protect (Proteger), Detect (Detectar), Respond (Responder) e Recover (Recuperar). Como diferencial, propõe-se a implementação de um sistema computacional capaz de converter respostas de um questionário estruturado em um dashboard visual de indicadores de risco, oferecendo suporte à tomada de decisão.

Referencial Teórico

Segurança Cibernética no Ambiente Educacional

Nos últimos anos, houve um aumento significativo na adoção de tecnologias em escolas e universidades, abrangendo tanto as atividades educacionais quanto as administrativas, o que resultou em um incremento na quantidade de dados sensíveis. Apesar das vantagens oferecidas por essa transformação, surgiram novos perigos. Embora tenha ocorrido uma leve diminuição no número de ataques, instituições de ensino continuam a ser alvos frequentes, com casos recentes de sequestros de dados e vazamentos de informações. Além disso, uma parte considerável ainda carece de

uma infraestrutura de segurança adequada, tornando-se suscetível a ameaças como phishing e vulnerabilidades em sistemas, o que enfatiza a importância da segurança da informação como um aspecto estratégico.

Marcos Legais e Regulatórios

Lei Geral de Proteção de Dados (LGPD)

A proteção destes dados é pautada por legislações como a LGPD no Brasil, que dispõe princípios como transparência e segurança, prevendo ainda proteção especial para dados de crianças (Art. 14). Em nível internacional, legislações como GDPR e FERPA evidenciam que a implementação de medidas de segurança é mandatória.

Estatuto da Criança e Adolescente (ECA) e Lei 14.181/2021

Além da LGPD, o ECA (Lei 8.069/1990) estabelece proteção especial a menores. A Lei 14.181/2021 ("Lei sobre Proteção de Dados de Menores") vai além, exigindo:

- Consentimento parental explícito e informado
- Direito ao esquecimento garantido
- Segregação de dados de menores
- Monitoramento de acesso

Essas legislações reforçam a necessidade de um indicador específico de risco para dados de menores, diferenciando-o de avaliações genéricas de segurança.

Frameworks de Segurança

NIST Cybersecurity Framework (CSF) 2.0

O NIST CSF 2.0 está no topo da lista de frameworks, porém, é organizado em funções de governança, identificar, proteger, detectar, responder e recuperar que compõem a segurança. Esse modelo permite uma avaliação a nível de maturidade das entidades podendo estas ser classificadas como iniciais, intermediárias e avançadas, ligada a isso está a possibilidade de identificar melhorias.

Estratégias Modernas: Zero Trust

Além disso, estratégias modernas como Zero Trust enfatizam a necessidade de não confiar automaticamente em acessos, particularmente em ambientes de uso de dispositivos pessoais e serviços em nuvem. Defeitos em sistemas e fornecedores também parecem estar entre as maiores áreas de risco.

Consequentemente, este artigo apresenta uma abordagem prática para avaliar a segurança digital em instituições de ensino, tomando como referência o NIST CSF e analisando-o à luz dos princípios da LGPD. A proposta envolve o uso de um questionário para gerar indicadores de risco apresentados em um painel de controle, visando apoiar a tomada de decisões de forma simples e eficaz.

Metodologia

Tipo e Escopo de Pesquisa

O escopo deste estudo é prático, com uma abordagem qualitativa e quantitativa, visando à elaboração de um modelo de avaliação da maturidade em segurança digital para instituições de ensino.

Fase 1: Revisão Bibliográfica e Fundamentação Teórica

Inicialmente, foi realizada uma revisão da literatura com base em estruturas de cibersegurança, como o NIST Cybersecurity Framework (CSF) 2.0, bem como na legislação vigente, principalmente a Lei Geral de Proteção de Dados (LGPD). Esta etapa teve como objetivo fundamentar teoricamente a proposta e identificar práticas que poderiam ser adaptadas à área educacional.

Fase 2: Definição de Controles Específicos para Educação

Estrutura de 3 Dimensões

Os controles foram selecionados e estruturados em uma matriz com 3 dimensões:

DIMENSÃO 1: TIPO DE CONTROLE

- Técnico: Firewalls, criptografia, MFA, IDS/IPS, backups automatizados
- Administrativo: Políticas documentadas, processos formais, atribuições de responsabilidade
- Físico: Acesso a datacenters, proteção de backups físicos, controle de dispositivos

DIMENSÃO 2: CONTEXTO EDUCACIONAL

- Dados de Menores: Proteção reforçada (LGPD Art. 14 + ECA + Lei 14.181)
- Dados Acadêmicos: Histórico escolar, boletins, frequência
- Dados Sensíveis: Informações socioeconômicas, saúde, necessidades especiais
- Dados de Pesquisa: Propriedade intelectual, resultados de estudos

DIMENSÃO 3: NÍVEL DE IMPLEMENTAÇÃO (Maturidade)

- Nível 1 (Inicial): Inexistente - sem documentação ou processos
- Nível 2 (Intermediário): Processos documentados, implementação manual
- Nível 3 (Gerenciado): Processos formais, auditoria regular, automação parcial
- Nível 4 (Otimizado): Automação completa, ML para detecção, melhoria contínua

Seleção de 50+ Controles NIST para Educação

A partir do NIST CSF, foram selecionados e adaptados para o contexto educacional aproximadamente 50 controles específicos, incluindo:

- Mapeamento às categorias NIST (Identify, Protect, Detect, Respond, Recover)
- Referência legislativa (LGPD, ECA, Lei 14.181)
- Custo estimado de implementação
- Impacto no nível de maturidade

Fase 3: Desenvolvimento do Questionário e Indicadores

Estrutura do Questionário

Um questionário estruturado foi desenvolvido com base nos 50+ controles, permitindo que instituições educacionais auto-avaliem seu nível de maturidade. O questionário inclui:

- Perguntas binárias (sim/não) para controles básicos
- Perguntas de escala Likert (1-5) para avaliação de maturidade
- Perguntas abertas para contexto específico da instituição
- Seções separadas para cada função NIST

Cálculo de Indicadores Ponderados

Indicador 1: Score de Maturidade Geral

Score_Geral = (Controles_Implementados / Total_Controles) × 100

Intervalo: 0-100%

Classificação:

- 0-25%: Crítico (Nível 1

- 26-50%: Baixo (Nível 2

- 51-75%: Médio (Nível 3

- 76-100%: Otimizado (Nível 4

Indicador 2: Score por Função NIST

Score_NIST[Função] = (Controles_Implementados_Função / Total_Controles_Função) × 100

Para cada função: Identify, Protect, Detect, Respond, Recover

Indicador 3: Risk Score para Dados de Menores (RSDM)

RSDM = (Controles_Menores_Implementados / Controles_Menores_Necessários) × 100

Controles específicos para menores incluem:

✓ Segregação de dados (LGPD Art. 14 + ECA)

✓ Consentimento parental documentado

✓ Direito ao esquecimento (delete policy automática)

✓ Criptografia de dados em repouso

✓ Acesso restrito (logging de quem acessa dados de menores)

✓ Monitoramento de acesso (alertas de anomalia)

✓ Incidente response plan específico para menores

Exemplo prático:

- Escola X implementou 4 de 7 controles = RSDM = 57% (CRÍTICO)

- Universidade Y implementou 7 de 7 = RSDM = 100% (OTIMIZADO)

Indicador 4: Índice de Conformidade LGPD

LGPD_Index = (Controles_LGPD_Obrigatórios_Implementados / Total_Obrigatórios) × 100

Fase 4: Sistema de Dashboard e Visualização

Um sistema foi implementado para converter os resultados do questionário em visualizações gráficas através de 4 dashboards distintos, cada um otimizado para seu público:

Dashboard Gestor (Diretor/Reitor)

Objetivo: Suportar decisões de investimento e risco

Visualizações:

- Score geral de segurança (1-100) com tendência
- Risco financeiro estimado (R$ em risco)
- % de conformidade LGPD
- Top 5 ações recomendadas prioritárias
- Comparativo com pares (benchmarking)

Frequência de atualização: Trimestral

Dashboard Técnico (CTO/Gestor TI)

Objetivo: Orientar implementação e roadmap técnico

Visualizações:

- Score por função NIST (Identify, Protect, Detect, Respond, Recover)
- Matriz de esforço vs impacto dos gaps
- Roadmap de 12 meses (fases, custos, prioridades)
- Vulnerabilidades críticas por categoria
- Testes de recuperação e status

Frequência de atualização: Mensal

Dashboard Operacional (Day-to-day)

Objetivo: Gerenciar tarefas diárias de compliance

Visualizações:

- Checklist de tarefas de compliance
- Status de incidentes em andamento
- Alertas de backups e testes de recuperação
- Renovação de certificados e renovação de MFA
- Logs de acesso anômalo

Frequência de atualização: Diária/Real-time

Dashboard Conselheiro (Board/Governança)

Objetivo: Governança estratégica de risco

Visualizações:

- Risk appetite vs risk posture (gap visual)
- Investimento em segurança vs benefício (ROI)
- Comparativo com pares nacionais/regionais
- Tendências ano-a-ano (melhorando/piorando?)
- Matriz de probabilidade x impacto

Frequência de atualização: Semestral

Fase 5: Validação Piloto Estruturada

O modelo será submetido a uma validação estruturada em 5 fases com 3 instituições educacionais:

Fase 1: Seleção (Mês 1-2)

Critérios de Elegibilidade:

- Representatividade: 1 escola pública, 1 privada, 1 universidade
- Porte: 200-2000 alunos (controlar por variável)
- Infraestrutura: Mínimo Windows + Linux, acesso à internet confiável
- Compromisso: Gestor dedicado (20h/mês para participação)

Documentação:

- Acordo de parceria
- Termo de consentimento
- Acordo de confidencialidade

Fase 2: Baseline (Mês 2

Atividades:

- Aplicar questionário NIST completo (pre-assessment)
- Documentar score inicial (ex: Escola A = 23%)
- Mapear infraestrutura atual (software, hardware, processos)
- Entrevistas com stakeholders (TI, direção, jurídico, pedagógico)

Entregável: Relatório de baseline com fotografias do estado atual

Fase 3: Intervenção (Mês 3-6)

Atividades:

- Recomendar e implementar controles priorizados
- Reuniões mensais (feedback loop contínuo)
- Ajustar recomendações conforme descobertas
- Documentar todas as ações tomadas

Entregável: Case study em progresso

Fase 4: Post-Assessment (Mês 6

Atividades:

- Reaplicar questionário NIST (exato como pre-assessment)
- Medir deltas (Escola A: 23% → 61%)

- Validar efetividade dos dashboards (usados? adotados?)
- Entrevistas de satisfação e lições aprendidas
- Documentar problemas encontrados e soluções

Entregável: Relatório final + case study completo

Fase 5: Refinamento (Mês 6-12)
Atividades:

- Incorporar feedback das 3 instituições no modelo
- Atualizar questionário e indicadores conforme necessário
- Preparar publicação de resultados
- Planejar escalabilidade (como replicar?)

Roadmaps de Implementação Realista

Para demonstrar viabilidade, são propostos 3 roadmaps de 24 meses com custos:

Roadmap: Escola Pequena (1-500 alunos)
ANO 1 → Nível 1 para 2 (Aproximadamente R$15.000)

Semanas 1-2:

- Criar e documentar política de senhas
- Implementar controle de acesso físico básico

Semanas 3-4:

- Estabelecer protocolo de backup (manual, documentado)
- Treinar staff em backup

Mês 2:

- Implementar MFA para contas administrativas
- Configurar firewall básico

Mês 3-6:

- Treinamento de segurança para todos (2 sessões)
- Audit externa de conformidade LGPD (consultoria)

ANO 2 → Nível 2 para 3 (Aproximadamente R$50.000)

- Firewall gerenciado com logging
- IDS/IPS básico
- Automação de backups
- Testes de recuperação trimestrais
- Documentação formal de incidentes

Roadmap: Universidade (3k-10k alunos)
ANO 1 → Nível 1 para 3 (Aproximadamente R$200.000+)

- Infraestrutura zero-trust (redesenho de rede)
- SOC (Security Operations Center) — parceria ou contratação

- Automação completa de backups com replicação
- Conformidade LGPD + ISO 27001 (audit e remediação)
- Programa de conscientização em larga escala

Resultados e Discussão

Resultados Imediatos

- Identificação de gaps de maturidade em 3 instituições-piloto
- Validação de efetividade do modelo em contexto real
- Feedback para refinamento dos indicadores
- Case studies documentados

Resultados de Médio Prazo

- Publicação de artigo em periódico educacional
- Validação científica do modelo
- Replicabilidade demonstrada em 3 contextos diferentes

Resultados de Longo Prazo

- Potencial para adoção nacional em instituições educacionais
- Base para políticas públicas de segurança digital em educação
- Spin-offs (produto SaaS, consultoria especializada)

Alinhamento com NIST CSF e LGPD

O modelo proposto alinha-se com as funções centrais do NIST CSF (Identify, Protect, Detect, Respond, Recover) enquanto incorpora requisitos específicos da LGPD, criando uma ponte entre conformidade e gestão de risco.

Diferenciação: Soberania Digital

A inclusão de elementos de soberania digital (dados no Brasil, infraestrutura própria, risco geopolítico) diferencia este trabalho de avaliações genéricas de maturidade, posicionando-o como ferramenta estratégica.

Inovação: Indicador RSDM

O indicador exclusivo para dados de menores (RSDM) preenche uma lacuna no mercado, abordando legislações específicas (ECA, Lei 14.181/2021) não cobertas por frameworks genéricos.

Implicações Práticas

- Como escolas podem usar este modelo para planejamento?
- Qual é o ROI esperado?
- Como implementar com recursos limitados?

Limitações do Estudo

- Escopo limitado a 3 instituições-piloto
- Contexto específico de educação brasileira (generalizável para outros países?)
- Dependência de auto-avaliação do questionário (viés de resposta)
- Modelo requer atualização contínua conforme legislação muda

---

Considerações Finais

Este trabalho apresenta um modelo prático e validado para avaliação de maturidade em segurança digital em instituições educacionais. O modelo diferencia-se por:

1. Integração LGPD + NIST: Combina conformidade com gestão de risco
2. Foco educacional: Controles específicos para dados de menores e contexto escolar
3. Soberania digital: Avalia autonomia operacional, não apenas compliance
4. Indicador RSDM: Métrica exclusiva para proteção de menores
5. Dashboards inteligentes: 4 visualizações para públicos distintos
6. Implementação realista: Roadmaps com custos e cronogramas

Com a implementação deste modelo, instituições educacionais poderão:

- Identificar vulnerabilidades críticas
- Planejar investimentos em segurança com base em dados
- Melhorar governança digital
- Cumprir obrigações legais
- Alcançar autonomia operacional

Recomenda-se a adoção deste framework como padrão de referência para o setor educacional brasileiro.

Curto Prazo (2026-2027)

- Expandir validação para 10-15 instituições adicionais
- Refinar indicadores baseado em feedback
- Publicar resultados em conferências

Médio Prazo (2027-2028)

- Desenvolvimento de plataforma SaaS
- Integração com sistemas de informação escolar (SIE)
- Treinamento de avaliadores certificados

Longo Prazo (2028+)

- Incorporação do modelo em políticas públicas (MEC)
- Relatório anual nacional de segurança digital em educação
- Expansão para contextos de educação a distância e educação indígena
- Desenvolvimento de certificação profissional
- Parcerias internacionais (UNESCO, ENISA)

Oportunidades Comerciais

- Produto SaaS: Plataforma de auto-avaliação + dashboards (R$500-2000/mês)
- Consultoria: Implementação de controles e roadmaps (R$50k-200k/projeto)
- Treinamento: Cursos e certificações (R$5k-20k por instituição)
- Relatórios: Benchmarking nacional anual
- Partnerships: Colaborações com fornecedores de segurança

Referências

Legislação e Frameworks

1. Brasil. Lei 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF.
2. Brasil. Lei 8.069, de 13 de julho de 1990. Estatuto da Criança e do Adolescente (ECA). Diário Oficial da União, Brasília, DF.
3. Brasil. Lei 14.181, de 27 de julho de 2021. Lei sobre Proteção de Dados de Menores. Diário Oficial da União, Brasília, DF.
4. NIST. Cybersecurity Framework Version 2.0. National Institute of Standards and Technology, 2024.
5. European Union. Regulation (EU) 2016/679. General Data Protection Regulation (GDPR). Official Journal of the European Union, 2016.

Pesquisa e Segurança em Educação

Artigos Científicos Relevantes

Apêndices

Apêndice A: Questionário Completo NIST para Educação

Exemplo:

FUNÇÃO 1: IDENTIFY (Identificar)

1. Sua instituição possui um inventário atualizado de todos os ativos
2. de TI (servidores, computadores, impressoras, etc)?
3. [ ] Sim, completo e atualizado
4. [ ] Parcialmente
5. [ ] Não existe
6. Existe documentação clara dos fluxos de dados de menores na instituição?
7. [ ] Sim, detalhada e conhecida por todos
8. [ ] Sim, mas incompleta
9. [ ] Não existe

Apêndice B: Matriz de 50+ Controles NIST para Educação

[CAMPO PARA EXPANSÃO: Tabela estruturada com:

- Controle NIST
- Categoria (Técnico/Administrativo/Físico)
- Contexto educacional (Menores/Acadêmicos/Sensíveis)
- Nível de implementação necessário
- Custo estimado
- Legislação relacionada